信息安全测评与风险评估

7.2.2 移动安全配置核查

授课教师：张玉



目录

CONTENTS

01 案例导入

02 学习目标

03 移动互联安全扩展要求——在等保中的位置

04 核心测评指标速览（重点）

案例导入——XcodeGhost：一夜之间，700款App中招

案例素材

2015年9月，开发者从网盘等非官方渠道下载了被植入恶意代码的开发工具Xcode（XcodeGhost），编译出的700余款App自带“后门”，波及上亿用户。



问题讨论

- ① 出问题的是手机、App，还是别的环节？
  ② 为什么不攻手机，而去攻“造App的工具”？
  ③ 记下问题，学完这节课我们一起揭晓。

案例里失守的关口，正是今天的主题——移动安全配置核查。

学习目标

通过本课学习，你将能够：

掌握**移动互联安全扩展要求**的测评指标（共9项）

能够 对无线接入设备的**认证、加密、入侵防范**进行核查

能够 识别**移动终端与应用管控**中的常见问题

能够 规范填写**《移动互联安全测评记录表》**

移动互联安全扩展要求——在等保中的位置

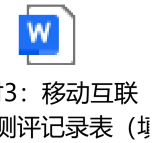
GB/T 22239-2019 安全扩展要求 → 移动互联安全扩展要求（第8.3节，适用于第三级系统）

五个测评维度

维度	控制点	数量
安全物理环境	无线接入点的物理位置	1项
安全区域边界	边界防护、访问控制、入侵防范	3项
安全计算环境	移动终端管控、移动应用管控	2项
安全建设管理	移动应用软件采购、移动应用软件开发	2项
安全运维管理	配置管理	1项

核心测评指标速览（重点）

移动互联安全测评 9大核心指标：



序号	控制点	核心要求	检查方法
1	无线接入点的物理位置	避免过度覆盖和电磁干扰	现场检查
2	边界防护	有线与无线之间必须通过无线接入网关设备	拓扑核查
3	访问控制	禁止使用WEP认证；口令长度8位	配置核查
4	入侵防范	检测非授权接入；禁用SSID广播、WPS；禁止多个AP共用同一密钥	配置核查+测试
5	移动终端管控	安装终端管理客户端；支持远程锁定/擦除	终端检查
6	移动应用管控	只允许指定证书签名的应用安装运行	策略核查

– WEP vs WPA——为什么等保明令禁止WEP？

WEP（Wired Equivalent Privacy） 已被证明存在严重安全漏洞，可在数分钟内被破解。

等保2.0明确要求“禁止使用WEP方式进行认证”。

对比项	WEP	WPA/WPA2	WPA3
加密算法	RC4（已破解）	AES（安全）	AES-256（更安全）
密钥管理	静态密钥	动态（4次握手）	动态（SAE）
破解难度	容易（数分钟）	困难	极难
等保合规	不合规	合规	合规

实践任务1——移动终端与应用管控核查（15分钟）



素材4：移动终端与应用管控核查表.d

要素	内容
任务名称	移动终端管控与移动应用管控核查
任务场景	MobLab实验平台“MDM终端管理”页面（模拟环境）
任务内容	① 检查终端管理客户端是否安装并运行；② 检查是否支持远程锁定/擦除功能；③ 检查是否存在root/越狱设备；④ 检查锁屏密码策略；⑤ 结合“企业应用库”面板核查应用签名管控；⑥ 填写《移动互联安全测评记录表》

教师演示——无线接入设备配置核查（15分钟）

演示场景：

打开MobLab实验平台“无线控制器（AC）”页面，逐项演示：



01	查看认证方式：	检查是否配置了WPA2-Enterprise认证
02	查看加密方式：	确认加密算法是否为AES
03	检查SSID广播：	确认是否禁用了SSID广播
04	检查WPS状态：	确认WPS功能已禁用
05	检查密钥管理：	确认是否多个AP使用同一认证密钥

实践任务2——无线接入安全配置核查（20分钟）

任务名称	无线接入认证与加密配置核查
任务场景	MobLab实验平台“无线控制器（AC）”页，边核查边填《测评记录表》
任务内容	①检查认证方式是否符合等保要求（非WEP） ②检查加密算法是否为AES ③检查SSID广播状态 ④检查WPS功能状态 ⑤检查是否多个AP共用同一认证密钥

实践任务3——入侵防范核查（日志分析，15分钟）

要素	内容
任务名称	入侵防范配置核查
任务场景	MobLab实验平台“无线入侵检测（WIDS）”页面
任务内容	①分析日志中是否发现非授权接入行为 ②检查是否配置了无线入侵检测/防御功能 ③检查是否检测到针对无线接入设备的攻击行为 ④填写《移动互联安全测评记录表》

移动互联安全测评常见问题

实战经验：以下问题在测评中反复出现

- 使用WEP认证 → 直接违反8.3.2.2要求
- SSID广播未关闭 → 违反8.3.2.3 c)
- WPS功能未禁用 → 违反8.3.2.3 d)
- 多个AP共用认证密钥 → 违反8.3.2.3 e)
- 未安装终端管控客户端 → 违反8.3.3.1 a)
- 允许安装非证书签名应用 → 违反8.3.3.2 b)

等保三级 vs 二级 —— 移动互联要求差异

等保二级也有移动互联要求，但相对简化，三级更加严格。

测评指标	等保二级	等保三级（增强）
无线接入认证	开启接入认证功能，禁止WEP，口令8位	支持认证服务器认证或密码模块认证
入侵防范阻断非授权设备	未作明确要求	应能够阻断
移动终端管控	具有选择应用安装、运行的功能	增加：只允许指定证书签名的应用安装运行
移动终端管控远程控制	无明确要求	应接受远程锁定、远程擦除等

– 与云计算/物联网/工控扩展要求的关联

移动安全与其他扩展要求的交叉融合：



移动 + 云：移动应用的数据存储在云端 → 需结合云安全扩展要求（数据保密性、完整性）



移动 + 物联网：智能手机作为物联网的“移动终端” → 需结合物联网安全要求



移动 + 工控：移动设备远程操控工控系统 → 需结合工控系统安全要求

思政融入——供应链警觉：新一代安全人的必修素养

守护

XcodeGhost里，风险从“贪快”从网盘下载工具那一刻就已埋下。守住正规渠道，就是守住亿万用户的第一道防线。

规范

配置核查的目光不能只盯运行中的设备，还要追问：App和工具从哪来？渠道与配置的规范，是移动安全的第一道闸门。

自觉

供应链警觉是新一代安全人的必备素养。测评师既查设备配置，也守供应渠道——把警觉变成职业本能。

知识点回顾（5分钟）

移动安全配置核查

一、移动互联安全扩展要求

- 五个维度：物理环境/区域边界/计算环境/建设管理/运维管理

9大核心测评指标

二、无线接入安全核查重点

- 认证方式：禁止WEP，≥WPA2
- 加密算法：AES
- SSID广播：必须关闭

三、入侵防范

- 检测非授权接入
- 阻断非授权设备（三级）

四、终端与应用管控

- 安装MDM客户端
- 远程锁定/擦除
- 应用证书签名管理

课后作业

导出《移动互联安全测评记录表》和评分截图，提交至学习通平台

完成活动7.2在线测试（选择题+判断题，共15题）

在自己手机中检查Wi-Fi设置，确认是否启用了WPA2加密（截图提交）

预习7.3.1“物联网架构认知”相关内容

下节课预告

7.3.1 物联网架构认知

01

物联网三层架构（感知层、网络传输层、处理应用层）

02

物联网安全扩展要求概述

03

感知层安全风险分析

课堂小结与答疑

回应开课之问	① 攻的是“生产App的工具”，而非手机本身； ② 不规范渠道+不合规配置，让风险流入上亿手机； ③ 这正是移动安全配置核查要守住的关口
两个关键技能	① 能核查无线接入认证、加密与密钥配置； ② 能核查终端管控并识别常见违规配置
思政落点	供应链警觉+规范意识：正规渠道、合规配置——守护亿万用户数据与国家移动办公安全

感谢观看

